MANUAL DEL SOC N1

Manual operativo del SOC N1

Roles, clasificación, triage, escalamiento, turnos, niveles de servicio y métricas

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva

Control documental	Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.

1. Alcance y contexto

Caso de la rúbrica: fintech de pasarela de pagos y billetera digital, 10 empleados, operación híbrida, 20 activos (11 Windows 11, 5 macOS, 4 Ubuntu Server). Activos críticos: API de pagos en nube, réplica de BD, bastión administrativo y llaves de cifrado. VPN sitio a sitio con la VPC transaccional.

Identificadores operativos de referencia (no deben interpretarse como nombres reales verificados): C05-WIN-01 a 11 (Windows), C05-MAC-01 a 05 (desarrollo); C05-SRV-01 bastión, C05-SRV-02 réplica de BD, C05-SRV-03 aplicación y C05-SRV-04 respaldos. Host observado en el laboratorio: NELSON / Windows-Agent.

Objetivo: atender alertas de Wazuh, Kaspersky y fuentes de infraestructura; filtrar falsos positivos, preservar trazabilidad y escalar oportunamente sin exceder la autoridad de Nivel 1. Este manual no sustituye aprobaciones de cambios, decisiones forenses ni procedimientos de continuidad.

2. Arquitectura funcional y fuentes

Fuente	Eventos relevantes	Activos cubiertos
Wazuh SIEM	Autenticación Windows/Linux, syscheck FIM, vulnerabilidades, SCA y reglas locales.	Estaciones y Ubuntu Server; logs accesibles según permisos.
Kaspersky EDR	Malware, protección web, cuarentena, control de dispositivos y comportamiento.	Endpoints con agente y licencia activos.
NGFW / VPN	Inicio de sesión remoto, cambios de origen, barridos, bloqueos IPS y túnel sitio a sitio.	Perímetro/VPC, según telemetría habilitada.
Nube / aplicación	Accesos de API, cambio de configuración, integridad y error de servicios.	API de pagos y servicios IaaS, sujeto a integración.

3. Roles y responsabilidades

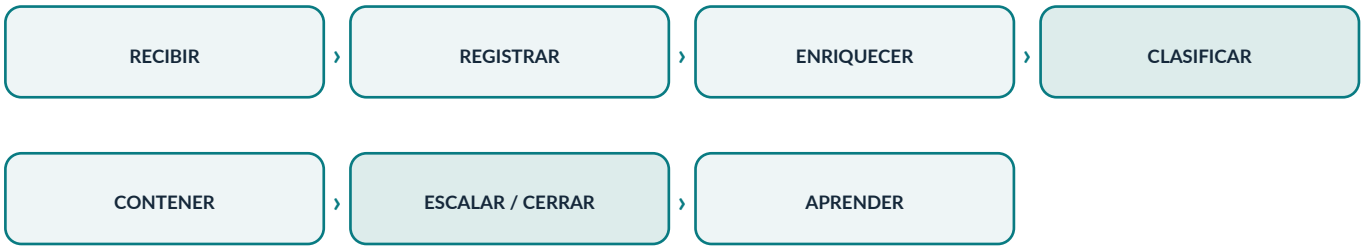
Rol	Funciones operativas	Autoridad / límite
Analista SOC N1	Monitoreo, triage, enriquecimiento, evidencias y contención de bajo riesgo.	No forense; no cambios de cuentas privilegiadas ni reinicios críticos.
Soporte N2	Investigación avanzada, erradicación, contención crítica y recuperación autorizada.	Ejecuta acciones especializadas con aprobación.
Responsable del SOC	Gobierno, métricas, revisión de severidad, excepciones y autorizaciones.	Aprueba cambios a detecciones y excepciones.
Administrador TI	Acciones de sistemas, parches, cuentas, respaldos y restauración.	Aplica cambios bajo autorización.
Gerencia / cumplimiento	Riesgo empresarial, presupuesto, comunicaciones y asuntos de datos.	Decide notificaciones externas tras evaluación jurídica.

4. Matriz de severidad y escalamiento

Severidad	Criterio en C05	Reconocer	Escalar N2 / aviso
Crítica	Compromiso confirmado de API de pagos, llaves o BD; exfiltración, ransomware activo.	15 min	Inmediato, máximo 15 min tras confirmar; responsable SOC y gerencia por llamada.
Alta	Malware ejecutado, acceso admin anómalo confirmado, nuevo privilegio sin autorización.	30 min	Hasta 30 min tras confirmar; responsable del SOC.
Media	Intentos bloqueados, EICAR bloqueado aislado, anomalía que exige investigación.	2 h	Según disparadores del playbook; bitácora de respuesta.
Baja	Escaneo externo bloqueado, USB no autorizado sin copia de datos.	8 h hábiles	No estándar; registrar.
Informativa	Cambios aprobados o mantenimiento programado.	1 día hábil	Sin escalamiento ni notificación ordinaria.

Regla de prevalencia: elevar por criticidad del activo, impacto sobre pagos, exposición de datos o evidencias de movimiento lateral. La etiqueta inicial del sensor no determina automáticamente la severidad final.

5. Flujo de triage



Para un falso positivo o actividad autorizada: documentar la evidencia antes del cierre.

Paso	Procedimiento y salida mínima
01 Recibir	Identificar alerta y preservar original, UTC y America/Bogota; fuente, ID, regla, hash si existe.

Paso	Procedimiento y salida mínima
02 Registrar	Bitácora de incidente: hora, analista, activo, usuario, sistema y referencia cruzada.
03 Enriquecer	Historial del host, correlación ±30 min, reputación de IP/hash usando solo indicadores públicos.
04 Clasificar	Verdadero positivo, benigno autorizado, falso positivo o no concluyente; impacto C/I/D y prioridad.
05 Contener	Sólo acciones aprobadas en el playbook; registrar hora, responsable y reversión.
06 Escalar/cerrar	Entrega estructurada a N2 o cierre sustentado en pruebas; notificar según severidad.
07 Aprender	Documentar brecha, control compensatorio y propuesta de ajuste con aprobación.

6. Acciones permitidas y prohibidas

Puede ejecutar N1 cuando aplique	No puede ejecutar N1
Poner artefacto en cuarentena desde el EDR; preservar hash y evento.	Borrar evidencias o manipular archivos de manera irreversible.
Aislar un endpoint afectado con severidad alta/crítica y avisar a N2.	Apagar servidores críticos, reinstalar o restaurar equipos.
Bloquear temporalmente IP externa maliciosa con aprobación/política.	Modificar reglas, exclusiones o políticas sin cambio autorizado.
Solicitar bloqueo de cuenta no privilegiada al administrador.	Crear, eliminar o modificar privilegios de administradores.
Recomendar suspender interacción con correo o USB sospechoso.	Análisis forense invasivo u operaciones ofensivas fuera del alcance.

7. Plantilla de escalamiento a N2 (uso en bitácora o correo interno)

Campo	Contenido mínimo
Referencia interna	INC-C05-AAAA-NNN y fecha/hora de escalamiento (America/Bogota)
Severidad y SLA	Categoría, nivel, hora de reconocimiento y vencimiento
Resumen ejecutivo	2-3 líneas: qué ocurrió, alcance y riesgo
Activos / usuarios	Host, rol, servicio de pagos/BD, cuentas, ubicación lógica
Línea de tiempo	Hora, evento, origen, acción y responsable
Evidencias	Alert ID, rule ID, hash, IP, rutas, capturas y ruta de custodia
Acciones N1	Qué se contuvo, autorización, hora y reversibilidad
Hipótesis y confianza	Hipótesis, confianza alta/media/baja y puntos no confirmados
Solicitud a N2	Decisión concreta (forense, aislamiento, revocación, restauración)
Contacto y confirmación	Analista, canal autorizado, recepción por N2 y hora

8. Turnos y continuidad

Franja	Cobertura propuesta	Responsabilidad
L-V 07:00-15:00	Monitoreo activo, Analista A	Toda severidad.
L-V 11:00-19:00	Monitoreo activo, Analista B (solape 4 h)	Toda severidad y relevo.
Noches y madrugadas	Guardia rotativa semanal por notificación	Alta y crítica. Acuse de guardia ≤30 min; para crítica prima SLA de 15 min.
Fines de semana y festivos	Guardia rotativa + 2 revisiones programadas/día	Atención alta/crítica por notificación.

Relevo: (1) incidentes abiertos; (2) acciones de contención; (3) compromisos de SLA; (4) ventanas de cambios; (5) cambios de indicadores; (6) responsables de guardia. Esquema propuesto sujeto a disponibilidad del equipo y normas laborales.

9. SLA del SOC y criterios de medición

Severidad	Reconocer	Triage completo	Escalar N2	Contener/resolver	Cobertura
Crítica	15 min	30 min	≤15 min tras confirmar	4 h	24x7 guardia
Alta	30 min	1 h	≤30 min tras confirmar	8 h	Laboral + guardia
Media	2 h	4 h	Según playbook	24 h	Laboral
Baja	8 h hábiles	1 día hábil	No aplica	72 h	Laboral
Informativa	1 día hábil	No aplica	No aplica	5 días hábiles	Laboral

Cómputo: reloj desde primera alerta hasta acuse y triage; pausar sólo por causa expresamente autorizada. Meta del SOC: ≥90% de cumplimiento. Para la misma señal prevalece el plazo más exigente de la matriz.

10. Indicadores de gestión y fuentes

KPI	Fórmula	Fuente	Meta
MTTD	Promedio(alerta − inicio del evento)	Tiempos EDR/SIEM	≤15 min alta/crítica
MTTA	Promedio(1.ª acción N1 − hora de alerta)	Bitácora N1 + alerta	≥90% dentro del SLA
MTTR	Promedio(contención/cierre − hora alerta)	Bitácora de incidentes	≤ SLA de severidad
Falsos positivos	N.º falsos positivos / alertas cerradas ×100	Clasificación de casos	<30% al mes 3
Cumplimiento SLA	N.º dentro de plazo / total casos ×100	Bitácora + matriz SLA	≥90%
Alertas severidad	Conteo mensual por severidad	SIEM + bitácora	Informativo
Tasa escalamiento	N.º casos a N2 / total ×100	Bitácora	Revisión mensual
Cobertura agentes	Agentes activos / 20 equipos ×100	Inventario, Wazuh, EDR	≥98%
CVE críticas antiguas	N.º CVE críticas sin corregir >30 días	Wazuh vulnerabilidades	0

Ejemplo de control del cálculo: 5 alertas reconocidas en 10, 20, 5, 40 y 15 minutos => MTTA=18 min. Son datos ilustrativos de la rúbrica, no métricas observadas de PagoClaro.

11. Retención, confidencialidad y custodia

- Usar identificador de incidente consistente, hora original y zona America/Bogota; registrar cualquier conversión UTC.
- Archivar eventos originales y hash SHA-256 de copias de evidencia cuando exista; no modificar originales.
- No registrar PAN completo, credenciales, tokens, claves de API ni datos financieros sensibles en evidencia académica.
- La retención y el acceso deben ajustarse a la política aprobada del caso; la rúbrica enfatiza trazabilidad y conservación de registros.
- Mantener diferencia visible entre ejercicios simulados, pruebas controladas reales y alertas confirmadas.

12. Verificación del procedimiento

Checklist: tipo y fuente registrados; alcance C05 comprobado; severidad razonada; acuse oportuno; línea de tiempo; fuentes preservadas; acción autorizada; decisión de cierre o escalamiento; responsable del relevo; lección y recomendación.

13. Base documental

Fuente normativa del ejercicio: Parcial_SOC_N1_Etica_Hacking, Fase 6, págs. 62-69, y anexos D y F, págs. 83-84. El caso C05 se define en la pág. 18. Documento elaborado para ejercicio académico.